

GovRed-Health: Đánh giá sai lệch quyền giữa thời điểm AI được phép đọc dữ liệu và thời điểm ghi bền vững

Nguyễn Ngọc Thiện, Trịnh Minh Quang
Trường THPT Hai Bà Trưng, Huế, Việt Nam

2026

Abstract

Các bộ đánh giá bảo mật dành cho tác tử LLM hiện đã bao phủ nhiều lớp rủi ro như prompt injection, lạm dụng công cụ, đầu độc bộ nhớ và kiểm tra quyền ở thời điểm ghi. GovRed-Health tập trung vào một vấn đề hẹp hơn trong AI y tế có trạng thái: mô hình có thể được phép đọc một phần hồ sơ ở thời điểm đầu, nhưng quyền truy cập hoặc trạng thái làm cơ sở cho lần đọc đó có thể thay đổi trước khi đề xuất của mô hình được ghi bền vững. Chúng tôi gọi hiện tượng này là *sai lệch quyền từ đọc đến ghi* (authorization drift). Mỗi ca thử nghiệm là một lịch logic ghép cặp: hệ thống cung cấp cho mô hình một bối cảnh sức khỏe đã qua quản trị, sau đó chủ động thay đổi một điều kiện như chủ thể, đồng thuận, chính sách, vai trò, mục đích, trạng thái, bộ nhớ đệm hoặc ảnh chụp ngữ cảnh trước khi thử ghi. Các lịch được thực thi xuyên qua HTTP/API, lớp phân quyền, bộ nhớ đệm/chỉ mục, PostgreSQL và dấu vết kiểm toán. Trong đợt chạy đã khóa 2026-08-17-rivf-final-003, mỗi nhánh thử nghiệm có 270 lịch; tập phân tích chính gồm 210 lịch có thể thực thi ở mỗi nhánh. Theo chỉ số tổng hợp không an toàn đã khóa trước, tỷ lệ lần lượt là 57,1% ở Unbound, 42,9% ở State-Version-Only, 42,9% ở Snapshot-Bound-State-Only và 14,3% ở GLHS-Strict. Strict và Unbound có 90 lịch bất đồng theo hướng có lợi cho Strict và không có lịch bất đồng theo hướng ngược lại trong chỉ số tổng hợp này. Tuy nhiên, toàn bộ 30 trường hợp còn lại của Strict đều là lịch ghi trên trạng thái cũ trong điều kiện đồng thời mà thứ tự tuyến tính hóa không thể xác định; chúng được báo là *không xác định*, không phải thao tác ghi sai đã xác nhận. Các nhóm sai lệch quyền tuân tự không ghi nhận thao tác ghi Strict sai đã xác nhận, và không ghi nhận trường hợp cung cấp dữ liệu bị cấm trong 270 lịch ở bất kỳ nhánh nào.

1 Giới thiệu

Nghiên cứu bảo mật cho tác tử LLM đã chuyển từ các ví dụ jailbreak riêng lẻ sang những bộ đánh giá có thể tái lập. AgentDojo, Agent Security Bench và MPIB kiểm tra prompt injection, đầu độc bộ nhớ và nhiều lỗi an toàn khác; SecureClaw bảo vệ cả phía đọc dữ liệu nhạy cảm lẫn phía tạo hiệu ứng bên ngoài. Một nhánh nghiên cứu gần hơn với bài toán của chúng tôi cho thấy quyền từng hợp lệ có thể trở nên lỗi thời trước thời điểm ghi, và hệ thống tác tử đồng thời cần kiểm tra lại quyền dựa trên trạng thái chính sách hiện hành.

GovRed-Health không tuyên bố prompt injection, bộ nhớ có quản trị hay kiểm tra quyền tại thời điểm ghi là mới. Câu hỏi được đặt hẹp hơn: **sau khi mô hình đã thực sự sử dụng một phần dữ liệu sức khỏe được cung cấp đúng quyền, đề xuất ghi về sau có còn hợp lệ nếu một điều kiện của lần cung cấp dữ liệu hoặc của quyền ghi đã thay đổi hay không?**

Mỗi đơn vị đánh giá là một lịch logic ghép cặp:

cung cấp dữ liệu có quản trị → thay đổi trạng thái/quyền → thử ghi bền vững.

Tác vụ được giữ nguyên giữa các nhánh để sự khác biệt tập trung vào điều kiện quản trị bị thay đổi. Bộ đánh giá đồng thời kiểm tra xem dấu vết kiểm toán có tái dựng được phần dữ liệu AI đã nhìn thấy, thay đổi đã xảy ra, quyết định cho phép hoặc từ chối và hiệu ứng bền vững cuối cùng hay không.

2 Ranh giới tính mới

GovRed-Health không phải bộ đánh giá đầu tiên về bảo mật cho tác tử có trạng thái và cũng không giới thiệu một cơ chế phân quyền mới. Điểm mới có thể bảo vệ được là **đối tượng thực nghiệm theo lịch đọc-thay đổi quyền-ghi trong miễn y tế**. Phần dữ liệu mà mô hình thực sự nhìn thấy là một thành phần của chính đơn vị phân tích, thay vì chỉ là đầu vào phụ.

Thiết kế còn tách ba lớp bảo vệ: độ mới của trạng thái, độ mới của điều kiện quản trị và ràng buộc với đúng bối cảnh đã cung cấp cho AI. Kiểm tra phiên bản trạng thái có thể bắt một cuộc đua cập nhật hồ sơ nhưng không biết đồng thuận đã bị thu hồi; ràng buộc ảnh chụp có thể chứng minh đúng bối cảnh đã được dùng nhưng chưa chắc các điều kiện quản trị vẫn còn hiệu lực. Việc tách các lớp này giúp chỉ ra nguyên nhân của từng ca lỗi thay vì thu gọn tất cả vào một “điểm bảo mật” duy nhất.

3 Mô hình đe dọa

Một lần cung cấp dữ liệu có quản trị được biểu diễn khái quát bởi

$$H = (u, a, p, v_s, v_g, d, e, E),$$

trong đó u là chủ thể, a là tác nhân, p là mục đích, v_s là phiên bản trạng thái, v_g là tọa độ quản trị, d là mã băm, e là thời hạn và E là tập bằng chứng đã được phép cung cấp. Đề xuất P được tạo sau đó và yêu cầu một thay đổi bền vững đối với trạng thái.

Mô hình đe dọa giả định yêu cầu đã được xác thực nhưng có thể mang trạng thái phía khách đã cũ, gặp thứ tự đồng thời bất lợi, chứa nội dung không đáng tin trong hồ sơ hoặc chạy cùng một cập nhật hợp lệ khác. Chúng tôi không giả định kẻ tấn công đã chiếm quyền quản trị cơ sở dữ liệu hoặc nắm khóa bí mật của hạ tầng. Toàn bộ kết quả chính sử dụng dữ liệu tổng hợp.

4 Thiết kế đánh giá

Bốn nhánh nghiên cứu gồm Unbound, State-Version-Only, Snapshot-Bound-State-Only và GLHS-Strict. Đây là các cấu hình loại bỏ thành phần (ablation) nội bộ để tách vai trò của từng cơ chế; chúng không được mô tả như bản tái hiện đầy đủ của những hệ thống khác đã công bố.

Các nhóm lịch chính gồm: thu hồi đồng thuận sau khi dữ liệu đã được cung cấp; cập nhật chính sách; đổi vai trò hoặc mục đích; phát lại đề xuất sang chủ thể khác; thay đổi trạng thái rồi thử ghi dựa trên phiên bản cũ; thu hồi quyền nhưng tái sử dụng bộ nhớ đệm; sai thời hạn hoặc mã băm; một tiến trình cập nhật quản trị chạy đồng thời

với thao tác ghi; và tái dựng dấu vết kiểm toán. Prompt injection hoặc cố gắng đi vòng GST chỉ là các nhóm thử sức chịu đựng thứ cấp.

Chỉ số chính được tính ở cấp lịch logic. Các trường hợp Not Run được loại khỏi mẫu số đúng theo giao thức đã khóa và không bị quy về giá trị 0. Lỗi dịch vụ, deadlock và thứ tự đồng thời không xác định được báo riêng, thay vì bị tính như một lần “an toàn”.

5 Kết quả

Trong 210 lịch thuộc tập phân tích chính ở mỗi nhánh, tỷ lệ chấp nhận sai một thao tác ghi dựa trên trạng thái cũ hoặc quyền không còn hợp lệ là:

Nhánh thử nghiệm	Tỷ lệ chấp nhận sai
Unbound	57,1% (120/210)
State-Version-Only	42,9% (90/210)
Snapshot-Bound-State-Only	42,9% (90/210)
GLHS-Strict	14,3% (30/210)

Kiểm định McNemar chính xác giữa Strict và Unbound cho $b = 90$, $c = 0$, $p = 1,62 \times 10^{-27}$. Không ghi nhận trường hợp cung cấp dữ liệu bị cấm trong 270 lịch ở bất kỳ nhánh nào.

Điểm đáng chú ý là 30 ca còn lại của Strict không phân bố ở các lịch tuần tự như thu hồi đồng thuận, đổi vai trò hay cập nhật chính sách. Tất cả đều thuộc nhóm ghi trên trạng thái cũ trong điều kiện đồng thời, nơi dữ liệu quan sát hiện có chưa đủ để xác định chắc chắn thứ tự giữa thao tác ghi và tiến trình cập nhật. Vì vậy, kết quả không được dùng để tuyên bố an toàn đồng thời trong mọi trường hợp.

Diễn giải lại trường hợp đồng thời. Với các lịch đồng thời, kết quả được tách thành ba trạng thái: vi phạm xác nhận được, an toàn/xử lý từ chối xác nhận được, và thứ tự không xác định. Ba mươi trường hợp còn lại của Strict đều thuộc nhóm thứ ba; chúng không được gọi là thao tác ghi sai đã xác nhận và cũng không được tính là an toàn. Tỷ lệ 14,3% chỉ được giữ như giá trị của chỉ số tổng hợp đã khóa trước để bảo toàn khả năng tái lập. Các họ sai lệch quyền tuần tự không ghi nhận thao tác ghi Strict sai đã xác nhận.

6 Thảo luận

GovRed-Health cho thấy một yêu cầu HTTP trả về thành công không đồng nghĩa với việc hiệu ứng bền vững phía sau vẫn hợp lệ về mặt quản trị. Một yêu cầu có thể hoàn tất sau khi bối cảnh hoặc quyền từng làm cơ sở cho nó đã không còn hiện hành. Khi toàn bộ chuỗi được đặt trong cùng một lịch thực nghiệm, ta có thể thấy rõ cơ chế nào bắt được lỗi do trạng thái cũ và cơ chế nào bắt được lỗi do điều kiện quản trị thay đổi.

Đợt chạy đã khóa cho thấy kiểm tra phiên bản trạng thái loại được một phần lỗi, còn GLHS-Strict loại thêm các ca lệch quyền tuần tự đã thử. Tuy nhiên, việc không quan sát thấy cung cấp dữ liệu bị cấm trong tập lịch này không phải bằng chứng về bảo mật thông tin nói chung. Tương tự, 30 ca đồng thời chưa phân định được thứ tự buộc kết luận phải giới hạn ở **bằng chứng phần mềm trong phạm vi các lịch đã kiểm thử**.

7 Giới hạn

Bộ đánh giá hiện dùng một kiến trúc ứng dụng và dữ liệu tổng hợp. Bộ chuẩn tham chiếu chỉ nhận diện các lỗi có thể quan sát ở ranh giới cung cấp dữ liệu và ghi bền vững, không đại diện cho mọi dạng tổn hại quyền riêng tư. Các nhánh cố ý giảm cơ chế bảo vệ chỉ phục vụ nghiên cứu. Nghiên cứu không đánh giá chất lượng chẩn đoán, kết cục người bệnh, tuân thủ pháp luật hoặc các cuộc tấn công đã chiếm quyền hạ tầng.

8 Kết luận

GovRed-Health biến hiện tượng sai lệch quyền từ một khái niệm trừu tượng thành một lịch thử nghiệm có thể tái lập: dữ liệu được cung cấp có quản trị, một điều kiện trạng thái hoặc quyền thay đổi, hệ thống thử ghi và dấu vết kiểm toán được tái dựng. Trong tập phân tích chính đã khóa, GLHS-Strict giảm chỉ số tổng hợp không an toàn từ 57,1% xuống 14,3%; toàn bộ phần 14,3% còn lại là các lịch đồng thời có thứ tự không xác định, còn các họ sai lệch quyền tuần tự không ghi nhận thao tác ghi Strict sai đã xác nhận. Không quan sát thấy trường hợp cung cấp dữ liệu bị cấm ở bất kỳ nhánh nào. Kết quả này hỗ trợ tính nhất quán quản trị của phần mềm trong các lịch đã thử; nó không phải bằng chứng về an ninh mạng trong môi trường sản xuất hay hiệu quả lâm sàng.